# Implementation Plan: Registered Users & Role/Permissions Management

## Goal Description

Build a comprehensive, unified **User Management and Role-Based Access Control (RBAC)** system for **INEZA RESTO & COFFEE SHOP**. Currently, the admin portal displays static/mock staff and loyalty arrays in localStorage while real customer registrations live in MySQL ( `users` table). This project will:

1. Connect the **Registered Users & Staff Roles** dashboard directly to MySQL with live CRUD operations and local storage resilience.
2. Introduce a clear role hierarchy and permission matrix:
    - **Super Admin / General Manager**: Full access across all modules (Orders, Kitchen, Menu, Promos, Tables, Users, Settings).
    - **Head Chef / Kitchen Manager**: Restricted to Kitchen Queue ( `tab-kitchen` ), live order status progression, and stock availability.
    - **Floor Manager / Waiter**: Restricted to Table Dining Tracker ( `tab-tables` ), table reservations, and order status updates.
    - **Cashier & POS Billing**: Restricted to Orders table, payment settlement, and thermal tax receipt generation.
    - **Customer**: Storefront ordering, live order timeline tracking, loyalty rewards, and profile editing.
3. Add live user account status controls (Active vs. Deactivated / Suspended) and role assignment directly from the Admin portal.

## Role & Permission Matrix

| Role | Dashboard Overview | Live Orders | Kitchen KDS | Menu & Stock | Table Progress | Staff & Users | Reports / Analytics | Settings |
|---|---|---|---|---|---|---|---|---|
| **Super Admin** | ✅ | ✅ | ✅ | ✅ | ✅ | ✅ | ✅ | ✅ |
| **Head Chef** | ⚠️ View only | ⚠️ View only | ✅ Full (Prep/Ready) | ⚠️ Stock toggle only | ❌ | ❌ | ❌ | ❌ |
| **Floor Waiter** | ⚠️ View only | ⚠️ View only | ❌ | ❌ | ✅ Full (Clean/Occupied) | ❌ | ❌ | ❌ |
| **Cashier / POS** | ⚠️ View only | ✅ Settle & Print | ❌ | ❌ | ⚠️ View only | ❌ | ⚠️ View only | ❌ |
| **Customer** | ❌ (Storefront only) | ❌ | ❌ | ❌ | ❌ | ❌ | ❌ | ❌ |

## Architecture & Data Flow

## User Review Required

> IMPORTANT
>
> **Database Schema Enhancement**: We will add two lightweight columns to the `users` table via `api/db.php` if they do not exist:
>
> - `permissions`: (TEXT/VARCHAR) JSON string or comma-separated permissions for custom access grants.
> - `loyalty_points`: (INT default 0) to store real customer reward balances in the database rather than browser storage alone.

> NOTE

> **Graceful Role Enforcement in `admin.html`**: When a staff member logs in (e.g. Head Chef), the sidebar dynamically disables or hides modules they are not authorized to access (e.g., hiding Staff & Loyalty, Financial Analytics, or System Settings), preventing accidental config modifications.

## Proposed Changes

### 1. Database & Backend API Layer

**[MODIFY]**

- Add auto-migration check for `permissions` (text) and `loyalty_points` (int default 0) columns on `users`.
- Expand role enum to include `super_admin`, `admin`, `chef`, `waiter`, `cashier`, `customer` or standardize mapping.

**[NEW]**

- Dedicated RESTful API endpoint for User & Staff Administration:
  - `action=list`: Fetch all users (customers and staff) with search and role filters.
  - `action=create_staff`: Register new staff member with encrypted password and assigned role.
  - `action=update_user`: Modify user role, name, phone, or permission overrides.
  - `action=toggle_status`: Toggle user `is_active` (1 = Active, 0 = Suspended/Deactivated).
  - `action=grant_points`: Credit or debit customer loyalty points.
  - `action=delete_user`: Remove or soft-delete user account.

### 2. Staff & Admin Dashboard (`admin.html`)

**[MODIFY]**

- **Overhaul `tab-users` section**:
  - Sub-tab or dual table:
    1. **Active Staff Members & Roles**: Manage Super Admins, Head Chefs, Floor Waiters, and Cashiers.
    2. **Registered Customer Accounts**: Real-time list of all self-registered customers (name, email, phone number, loyalty points balance, registered date, and active status toggle).
  - Add search & filter bar for instant searching by name, phone, or role.
- **Enhanced Staff Modal**:

- Include specific role choices (`Super Admin`, `Head Chef`, `Floor Waiter`, `Cashier`).
- Add checkbox permissions:
  - `manage_orders`
  - `kitchen_kds`
  - `table_tracker`
  - `menu_stock`
  - `staff_users`
  - `financial_reports`

### 3. Client Administration Logic (`js/admin.js`)

**[MODIFY]**

- **Implement Live User Fetching**:
  - Replace static `localStorage` staff data with dynamic API calls to `api/users.php`, keeping local storage as a graceful offline fallback.
- **Sidebar & Tab Access Control (`enforceRolePermissions()`)**:
  - Check the active staff user's role on load.
  - Hide or lock restricted tabs based on role permissions.
- **Live User Actions**:
  - Add `toggleUserStatus(userId, currentStatus)` to activate/deactivate accounts in one click.
  - Add `editUserRole(userId, newRole)` modal.
  - Add `grantCustomerLoyalty(userId, points)` linked to MySQL.

## Verification Plan

### Automated / API Tests

1. **Fetch Users List**:
   - `GET api/users.php?action=list` ➔ Verify returns both staff and registered customers from MySQL.
2. **Create New Staff**:
   - `POST api/users.php?action=create_staff` with role `chef` ➔ Verify record inserted in DB with bcrypt password.
3. **Toggle Status**:

- `POST api/users.php?action=toggle_status` ➔ Verify `is_active` flips between 1 and 0.

4. **Grant Loyalty Points**:
   - `POST api/users.php?action=grant_points` ➔ Verify customer's `loyalty_points` increases.

## Manual Verification

1. **Admin Portal Walkthrough**:
   - Open `http://localhost/ineza_resto_cafe-shop/admin.html`.
   - Navigate to **Staff & Loyalty** tab (`#tab-users`).
   - Confirm real registered customers (such as `Patrick Kayonga`, `Lucas Lucavich`, etc.) appear in the Registered Customers table with their real phone numbers and registration dates.
   - Click **+ Add Staff Member**, fill in Chef details, and verify instant appearance in the Staff list.
   - Click **Deactivate / Activate** toggle on a customer account and verify status badge updates.
2. **Role Gatekeeping Walkthrough**:
   - Log in as Chef (`chef_jp`) ➔ Confirm kitchen tab is accessible, but Financial Analytics and Settings are restricted.